WM241-18
5655691

Fabulous Consulting Group: A Human-Centric Redesign of Cyber Security Systems

1 Executive Summary……[1]
2 Secure System Design……[1]
2.1 Situation……[1]
2.2 Task……[1]
2.3 Action……[2]
2.4 Result……[3]
Figure 1……[3]
3 Human Error……[3]
3.1 Situation……[3]
Figure 2……[3]
Figure 3……[5]
3.2 Task……[5]
3.3 Action……[6]
Figure 4……[6]
Figure 5……[7]
3.4 Result……[7]
4 Behavioural Change Intervention……[8]
4.1 Situation……[8]
4.2 Task……[8]
4.3 Action……[8]
4.4 Result……[10]
5 References……[11]
6 Appendix……[13]
6.1 Appendix A……[13]
6.2 Appendix B……[22]
6.3 Appendix C……[27]
6.4 Appendix D……[32]
6.5 Appendix E……[37]
6.6 AI Declaration……[42]

1 Executive Summary

This report, as requested by Fabulous Consulting Group, includes a comprehensive human factors audit of the client's current cybersecurity posture following a recent surge in phishing incidents and lackluster reporting culture, especially in the past 6 months. Through a dual-layered evaluation of systemic friction and individual cognitive processes, the findings indicate that the client's workforce is not displaying "user error", but is instead impacted by systemic negligence and information poverty.

The analysis and evaluation reveals that current security tools, such as Flawfinder, overload workers' cognitive ability. This creates an Information-Action Gap, where employees choose operational speed over following complex reporting protocols.

To mitigate these vulnerabilities, the following report proposes a shift from Compliance Theater to Security Habituation. Key interventions include Authentication Reform, Choice Architecture and Micro-Learning. By redesigning the environment to work with human intuition, the result is a sustainable security posture where the "secure path" becomes the natural response for every employee.

2 Secure System Design

2.1 Situation

As a human factors analyst of a leading international consultancy, Fabulous Consulting Group, I identified a critical failure in the client's decentralised reporting culture. Since they have a primarily remote work force, internal audits have revealed phishing incidents have risen significantly over the past six months, although reporting rates are low. This suggested whilst the employees may have ignored their training, and did not report these issues, they were potentially blocked by the systems designed to protect them from these threats. To see whether this was a failure of user compliance [1] or system design [2], I conducted an evaluation on the usability of professional security tools, specifically Flawfinder, a static analysis tool, as an example of the complex tools commonly used by staff.

2.2 Task

The objective was to establish how the behaviour of a user is influenced by the design of a secure system by assessing how Secure System Design affects user compliance and mental workload. My responsibilities involved moving beyond assessing the functionality of tools to the interaction design of the security information. I aimed to identify whether the company's reporting interface experienced Information Poverty [3] or Mental Strain [4], known for causes of tool abandonment. Two core methodologies were applied: the Heuristic Walkthrough identifying general design flaws, and the Cognitive Walkthrough identifying the user's thought process during a high-stress security task.

2.3 Action

A comprehensive evaluation was performed using the `openssl-1.0.1e` test suite as a benchmark, simulating the role of a developer responsible for security [Appendix A].

1. Heuristic Walkthrough: Whilst applying the 17 Information Needs, several critical violations were identified, most notably Flawfinder failing in Notification Text clarity and Visibility of System Status [5]. Upon scanning the test suite, the tool managed to generate 2949 “hits” [Figure A2], but these results were displayed in a static HTML list without categorisation [Figure A4]. In my analysis [Appendix A], I noted Flawfinder technically satisfies the Vulnerability Severity & Ranking requirement by assigning risk levels from 1 to 5 [Figure A9], however, further analysis reveals tool does not provide a justification for the ratings it has provided, a significant failure. For example when it flagged a Race Condition (CWE-362) as the highest risk, but a ranking without an Attack Scenario or Context [6] is essentially useless for non-experts who read the information.

2. Cognitive Walkthrough: Beyond the static rules, the Cognitive Walkthrough [Appendix A] focuses on the task of identifying and remediating a Risk Level 5 Race Condition - CWE-362 [Figure A9]. By putting myself into the user’s shoes, I identified a critical breakdown in the feedback loop. While the user may attempt to achieve the right result, the system fails at the final stage of “Will the user see that progress is being made?”. In Flawfinder, after applying a fix, like changing `chmod` to `fchmod`, the tool does not provide immediate confirmation. The vulnerability remains present in the static list of the exported html file until a manual re-scan is performed. This mirrors the problem seen in the company, as an employee can report a phishing email but is not provided with Status Visibility or “Success” notification, decreasing the user’s Motivation, a key component of the Kainda et al., Model [7]. The lack of Immediacy transforms an important security responsibility to a repetitive, unrewarding burden, explaining the“low reporting rates” despite a significant rise in phishing incidents in the past 6 months.

3. Real World Synthesis: These findings were cross-referenced with NCSC guidance [8], which argues security systems must support decision-making in addition to detection. The evaluation of the lab proved both Flawfinder and the client’s current reporting tool rely on Recall rather than Recognition. The system violates the Kainda Threat Model [7] by making it difficult for users to navigate or manually verifying the vulnerability rankings without context. In this model, users have finite Attentional Resources. When the employee at the financial firm is under time pressure, they perform a subconscious Cost-Benefit Analysis. If the “Ease-of-Use” of the threat, in this case ignoring the email instead of reporting it, is better than the “Efficiency” of the security tool, the user will default to taking the insecure path. The Information Poverty of 2949 hits provided without Actionable Fixes identified in the lab work causes the same Warning Fatigue at the company Fabulous Consulting is advising.

2.4 Result

The result of this dual-analysis is the realisation that the phishing detection tool is a Technically Secure system but is Humanly Fragile. By using the Kainda Security-Usability Threat Model [7], it can be shown that the current reporting process requires too much Attention and Vigilance from a workforce already suffering from Temporal Pressure.

After reflecting on the completed lab work, I realised that when Flawfinder gave 2949 hits, I wanted to ignore the tool instead of feeling more secure, as there were potential false-positives and the thought of having to manually verify each vulnerability is tiresome. Similarly, the employees at the financial firm would be overwhelmed by the alert overload and experience mental strain, proving users will abandon secure systems if human factors are ignored. For top-tier intervention, I propose the system design should move away from Vulnerability Ranking, seen to be insufficient in the lab, and towards Actionable Feedback later validated in the CyberSafe lab [Appendix D].

By simplifying the reporting path to a “One-Click” solution [Figure 1], the “User Control and Freedom” heuristic is satisfied and in turn reduces the Cognitive Load on staff, as well as aligning the security task with the user’s System 1 [9] processing of auto-piloting. Instead of forcing busy employees to switch to System 2 [9] to locate an obscured reporting link, this design makes the secure action the most natural, lowest-effort response to a suspicious stimulus. This integrates security seamlessly into the professional workflow and directly addresses the culture of non-compliance that was initially identified.

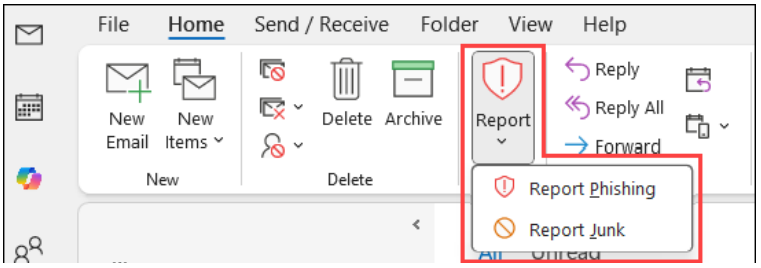


Figure 1: Example of an easily accessible report button [10]

3 Human Error

3.1 Situation

Having identified the financial firm’s reporting system was frustrating in STAR 1, I shifted my focus towards the “human element”. Although there was security awareness training in place, employees were increasingly falling for sophisticated phishing attacks in the past 6 months. As a Human Factors Analyst, I realised it was insufficient to label these incidents as mere user error and needed to understand the systematic and psychological influences of employees’ actions. In order to do this, I utilised both the HEAT Framework [Figure 2] and Bravo-Lillo’s Mental Models [11] to diagnose why the work environments might compromise human decision-making when faced with social engineering tactics, specifically the surge in phishing incidents identified by the client.

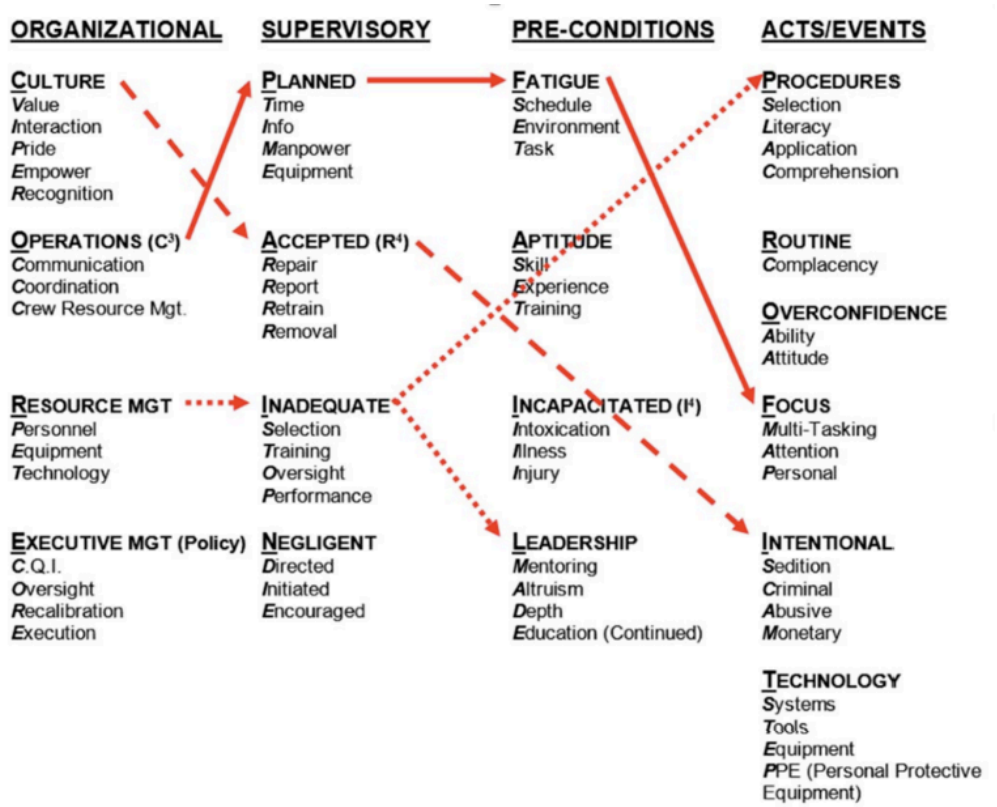


Figure 2: HEAT Framework [12]

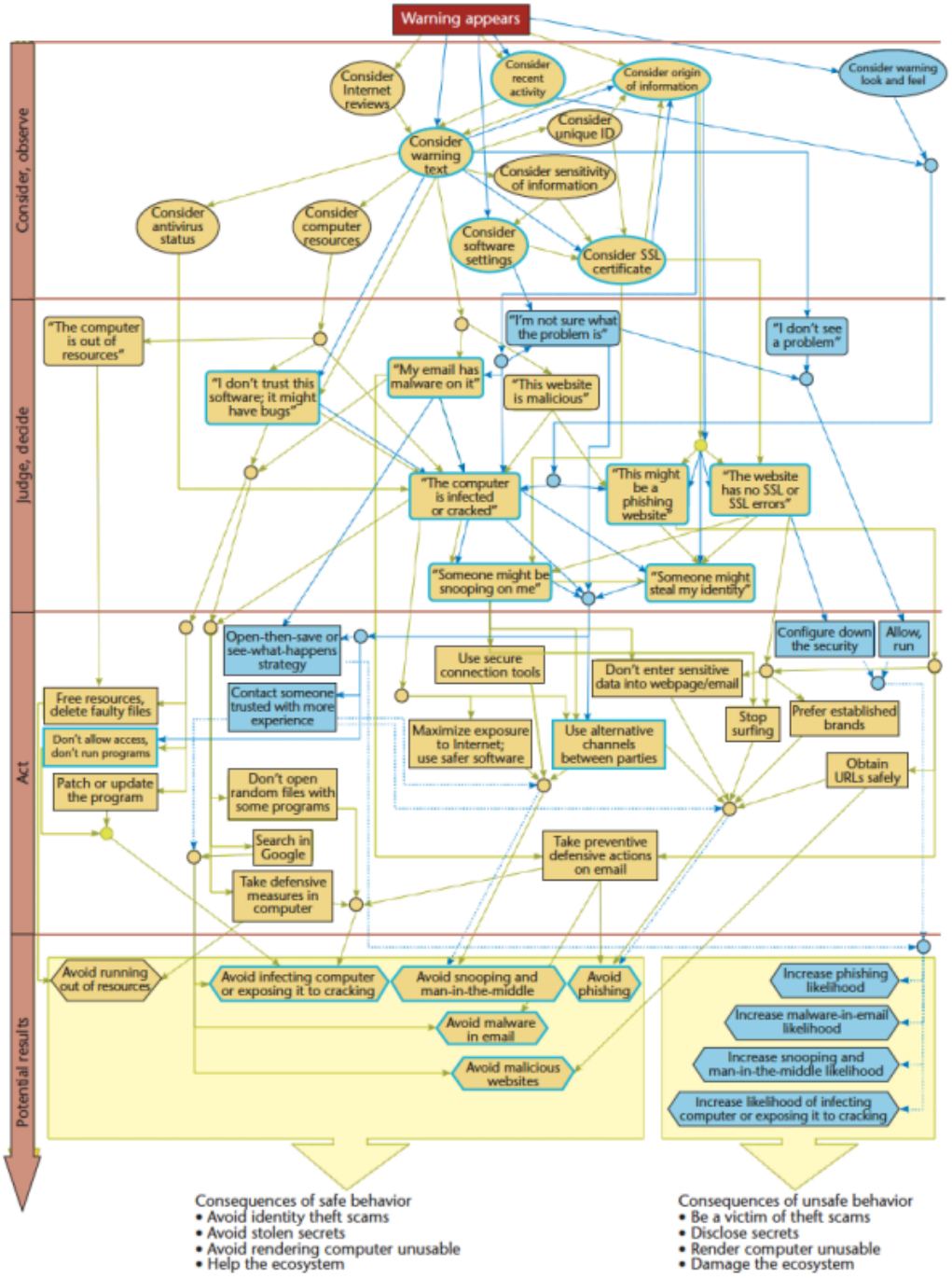


Figure 3: Bravo-Lillo's Mental Models [13]

3.2 Task

My investigation led me to categorise the types of human errors occurring within the firm and identify the Preconditions that would enable and make these phishing errors likely. The aim was to prove that clicking a malicious link is rarely an act of negligence or "stupidity", but rather a failure of Supervisory Influence combined with a mismatch between the system's warnings and the user's Mental Model. My responsibility involved identifying the psychological vulnerabilities, such as high cognitive load and urgency, that are systematically exploited by phishing actors within the firm's Organisational Culture (CORE).

3.3 Action

Another dual-layered analysis was conducted, connecting systemic organisational flaws to the individual cognitive processes by using the HEAT Framework [Appendix B] and Bravo-Lillo's Mental Models [Appendix C] as references.

1. Systemic Analysis: The firm's current phishing crisis was mapped to the HEAT Framework.

CORE (Organisational Culture): There was a parallel between the North American Casino Fish Tank (2018) Breach [Figure B4] and the client. In that scenario, they chose Aesthetic Innovation over Security Value. At the financial company, the shift to remote work prioritised Operational Continuity, creating a culture where the quick clearing of an inbox was utilised and valued over the slower and more methodological verification of email headers.

FAIL (Preconditions): My research into the DarkBeam (2023) breach [Figure B5] highlights that even "security experts" can fail when preconditions like Fatigue or High Workload are present [14]. I identified that the client's remote workers are under high Temporal Pressure, acting as a primary FAIL factor. This precondition leads to ACTS (Unsafe Acts), primarily Procedural Lapses where users overlook subtle phishing indicators such as Typosquatting [Figure 4], prioritising speed over thoroughness.

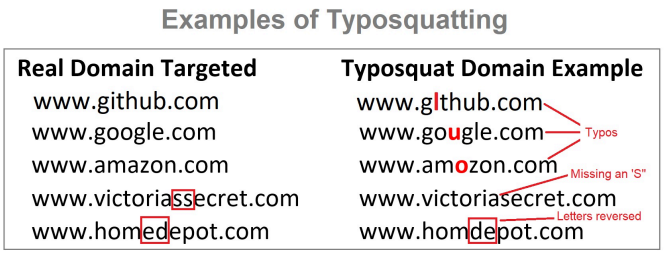


Figure 4: Examples of Typesquatting [15]

PAIN (Supervisory Influences): As identified in the DarkBeam breach [Figure B5], leadership failures often manifest as a lack of Planned Oversight, serving as the root cause for critical infrastructure misconfigurations. The analysis of the DataBeam case displays how the failure to audit administrative settings led to massive data exposure.. For the client, management trusted that remote staff would maintain high security standards without needing to implement a Recalibration of Goals [16], a strategic requirement in the HEAT framework necessitating adjustments in oversight mechanisms to reflect a decentralised workforce. By failing to provide Supervisory Correction [17] or a system to audit remote email habits, leadership facilitated the Normalisation of Deviance [18]. This is where risky, auto-pilot behaviours become the standard organisational response to high workloads, and the absence of effective management directly facilitated the recent rise in successful phishing attacks.

2. Psychological Analysis: Warning Response Mental Models
To examine the causes of users clicking on phishing links, I applied Bravo-Lillo et al.'s (2010) Mental Model [13]

Observation and Diagnosis: I categorised the firm's staff as "Novice Users" in regards to deceptive Visual Heuristics. Throughout my lab analysis of Scam Browser Redirects [Figure C2], it was noted that novices generally focus on "Surface-Level Cues" such as bright colours, urgent language and familiar logos. When an employee receives a phishing email that was designed to mimic an "Urgent IT Update" [Figure 5] or "Account Issues", their Diagnosis is manipulated by the Visual Authenticity such as a Microsoft logo rather than technical inconsistencies.

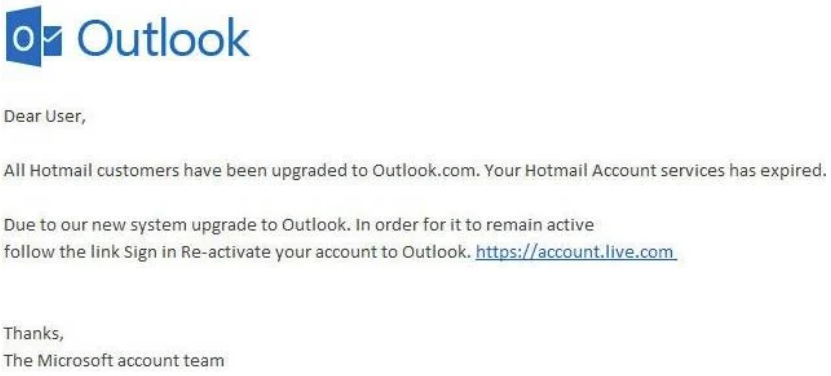


Figure 5: Example of an email account upgrade scam [19]

Action or Response: While an "Advanced User" [highlighted as the Yellow path in Figure 3], would perform a Reasoned Judgement by verifying the sender's actual email address, the Novice user at the firm would skip directly to the Action phase [Figure 3]. They click the malicious link with minimal consideration to "resolve" the simulated crisis created by the attacker, and continue with their work, signifying a failure of the system to support the user's Mental Model, as conventional email alerts do not provide users with safe mechanisms to verify a link's destination.

3.4 Result

The analysis demonstrates that the "Vulnerable Human" at the client firm is a product of Systemic Negligence (PAIN) and Environmental Preconditions (FAIL). By applying the Heat link (FAIL to ACTS) [Table B2], I proved that phishing success becomes statistically likely under conditions of fatigue and urgency, as opposed to individual failure.

Reflecting on this, a valuable insight is the existence of an Information-Action Gap [20]. While users are aware of the dangers of phishing, their "Heuristic Processing (System 1)" is manipulated by the urgency-based social engineering triggers. As I figured out in my Redesign Exercise [Figure C3], simply telling users to verify the link is ineffective when they are in an auto-pilot state. This confirms that the Information-Action Gap [20] cannot be bridged by more training alone, but needs the structural Nudges and Choice Architecture proposed in STAR 3 to bypass System 1 [9] vulnerabilities.

To reduce vulnerabilities, I suggest that the client should move from Fear-Based Phishing Drills to Fact-Based Interventions. As recommended in my lab work [Appendix C, Improvement 3], we replace suspicious external links with Integrated Safe Action Pathways, providing users with secure, system-mediated alternatives to direct link interaction. This aligns with the NCSCs Usable Security [21] principles by ensuring that even when users react instinctively to phishing stimuli, the system guides them towards a secure outcome without requiring high-effort Analytical Thinking (System 2) that is often exhausted during a busy workday.

4 Behavioural Change Intervention

4.1 Situation

The prior dual-analysis of the client firm reveals a Humanly Fragile security posture. Remote workers are stuck between a High-Friction System as identified in STAR 1 and High-Pressure Preconditions as identified in STAR 2. This has created a significant Information-Action Gap [20] where employees have completed basic training, but phishing incidents continue to increase whilst reporting remains low, suggesting a growing level of underreporting. As a Human Factors Analyst, I identified that the current strategy relies on outdated password rules and static training, ignoring the reality of human cognition and System 1 processing [9]. The current environment essentially punishes the user for merely being human, contributing to the Tool Abandonment and Warning Fatigue observed in my lab evaluations.

4.2 Task

My objective was to propose a Theory-Informed Intervention that evaluates the role of human factors to improve the current security practices at the financial firm. I aimed to replace the punitive security model with a Supportive Design [21] model. This involved a complete rebuild of the Reporting Interface, the Authentication Policy and the Training Delivery based on the findings in the CyberSafe Lab [Appendix D] and the Password Exercise Lab [Appendix E]. The primary goal was to move past Awareness and towards Behavioural Habituation, reducing Cognitive Load and using Nudge Theory [22] to make the secure path the path of least resistance.

4.3 Action

I created a three-part intervention strategy using Choice Architecture [23] and Nudge Theory [22] as the foundation, ensuring that every technical change is aligned with a psychological objective.

1. Architecture of Authentication: Transition to NIST-Aligned Passwords

To address the client's non-compliance, a comparative audit of their current authentication culture against modern standards was performed. While the client's specific internal policy was not explicitly documented, user workarounds and low reporting enabled the system to be characterised as a "Legacy Complexity Model", consistent with Policy C [Figure E4] evaluated in my lab research.

The Audit of Failure: In Policy C, I identified that requiring 14-character minimum passwords combined with mandatory emojis and a ban on dictionary words created an impossible memory burden [Appendix E, Policy C]. During the lab, I found that this Complexity Theater blocks legitimate users without deterring attackers. At the financial firm, this is seen as Cognitive Depletion. When a remote worker is forced to change an overly-complex password every 60 days, they exhaust the mental energy needed for heightened vigilance tasks like phishing detection. This explains why Fatigue was a primary precondition for error in my HEAT analysis (STAR 2).

The Nist-Informed Intervention: I proposed a Model Password Policy [Appendix E, Part 6] that strictly aligned with both NIST SP 800-63B and NCSC guidance. This strategic shift involved:

- **Removing Periodic Expiry:** NIST "shall not" require users to change arbitrarily. This eliminates pattern-making behaviour that makes their passwords more predictable.
- **Prioritising Length over Complexity:** Encouraging 12-15 character passphrases which are much easier for the human brain to Recall but simultaneously make it harder for machines to crack.
- **Supporting Password Managers:** By explicitly allowing pasting, the use of password vaults are encouraged, removing the need for the user to remember multiple unique credentials for each of their accounts.

2. The "One-Click" Ecosystem: Optimising Choice Architecture

To resolve the "Low Reporting" issue identified in STAR 1, I suggested a total restructure of the reporting interface, as the "Information Poverty" of the existing tools overwhelms the user, highlighted with Flawfinder's 2949 hits.

The Intervention: An integrated "One-Click Reporting Button" should be designed and implemented, placed within the email toolbar, which removes the Search Cost associated with locating the existing phishing report function.

The Theory of Choice Architecture: This utilises a Default Nudge [22]. By making the reporting tool the most visible visual stimulus, the system accommodates the Novice Mental Model [Figure C1] identified in STAR 2. By designing to guide the user's focus, we ensure that even a distracted employee can identify the reporting path through Recognition rather than Recall.

The Reward Loop: Incorporating my CyberSafe Lab [Appendix D], I integrated Positive Reinforcement. In the lab, I highlighted that simply completing a task is less effective than understanding the impact and receiving verification. Therefore, when a user reports a phishing attempt, they receive an immediate notification as confirmation of their action. This addresses the Motivation and Satisfaction factors of the Kainda et al. model [7], transform

3. Training as a "Nudge": From Static to Continuous Micro-Learning
My evaluation of the CyberSafe Training [Figure D3] revealed that one-time, short modules are Static Knowledge that fails to translate to Active Behaviour.

The Intervention: A shift towards a gamified, scenario-based, micro-learning experience was proposed, pushing the firm to implement frequent challenges such as "Spot the Phishing Attack".

The Theory: This approach addresses the Aptitude and Vigilance variables. By using "Recognition-based training", such as identifying a fake URL or a Typosquatted domain within a safe environment, we train the employee's System 1 processing [9] to instinctively recognise suspicious cues.

NCSC Strategic Alignment: Following the NCSC Certified Training benchmarks [Figure D4], this ensures training is both effective and easily understood, supporting better user engagement and retention, specifically tailored to address the human-centric vulnerabilities identified in the Casino Fish Tank (2018) and DarkBeam (2023) breaches, which demonstrate how prioritising operational convenience over security protocols leads to catastrophic systemic failures. This fosters a transition in the Organisational Culture (CORE) from passive compliance to a proactive, informed participation.

4.4 Result

After reflecting on the CyberSafe and Password labs, I have come to the conclusion that most effective security interventions are transparent, working alongside human intuition as opposed to fighting it. By simplifying authentication and gamifying training, we significantly alleviate mental strain for remote workers.

The outcome of this three-part strategy is a transition from Compliance Theater to Security Habituation. The Information-Action Gap [20] is bridged by ensuring that even an exhausted employee under Temporal Pressure can still act security through Heuristic System 1 processing. As a Human Factors Analyst, I have learnt that my role is not "fixing the user", but instead the environment that the user works in. By utilising Choice Architecture [23] it is ensured that a fail-safe is in place towards a secure outcome, addressing the systemic and psychological vulnerabilities identified throughout this consultancy engagement, building a sustainable, human-oriented security posture for the financial services company.

5 REFERENCES

[1]Herath, T & Rao, HR 2009, 'Protection motivation and deterrence: A framework for security policy compliance in organisations', *European Journal of Information Systems*, vol. 18, no. 2, pp. 106–125.

[2]Cranor, LF & Garfinkel, S (eds) 2005, *Security and usability: Designing secure systems that people can use*, O'Reilly, Sebastopol.

[3]Haider, J & Bawden, D 2007, 'Conceptions of "information poverty" in LIS: A discourse analysis', *Journal of Documentation*, vol. 63, no. 4, pp. 534–557.

[4]Cranor, LF 2008, 'A framework for reasoning about the human in the loop', in *Proceedings of the 1st Conference on Usability, Psychology, and Security (UPSEC)*, USENIX, Berkeley.

[5]Sasse, MA, Brostoff, S & Weirich, D 2001, 'Transforming the "weakest link"—a human/computer interaction approach to usable and effective security', *BT Technology Journal*, vol. 19, no. 3, pp. 122–131.

[6]Volkamer, M, Renaud, K & Kulyk, O 2019, 'Heuristics for evaluating the usability of security and privacy features', in M Furth & M Oostrum (eds), *Human aspects of information security, privacy, and trust (HAS 2019)*, Lecture Notes in Computer Science, vol. 11597, Springer, Cham, pp. 163–183.

[7]Kainda, R, Flechais, I & Roscoe, AW 2010, 'Security and usability: Analysis and evaluation', in *2010 International Conference on Availability, Reliability and Security (ARES)*, IEEE, Los Alamitos, pp. 275–282.

[8]National Cyber Security Centre (NCSC) 2019, *Secure by design: Improving security outcomes by enabling better decisions*, NCSC, London.

[9]Kahneman, D & Frederick, S 2002, 'Representativeness revisited: Attribute substitution in intuitive judgment', in T Gilovich, D Griffin & D Kahneman (eds), *Heuristics and biases: The psychology of intuitive judgment*, Cambridge University Press, Cambridge, pp. 49–81.

[10] chrisda 2025, *Report phishing and suspicious emails in Outlook for admins – Microsoft Defender for Office 365*, Microsoft Learn, https://learn.microsoft.com/en-us/defender-office-365/submissions-outlook-report-messages

[11]Parsons, K, McCormac, A, Butavicius, M, Pattinson, M & Jerram, C 2014, 'Determining employee awareness using the Human Aspects of Information Security Questionnaire (HAIS-Q)', *Computers & Security*, vol. 42, pp. 165–176.

[12] Wiegmann, DA & Shappell, SA 2003, *A human error approach to aviation accident analysis: The Human Factors Analysis and Classification System*, Ashgate, Aldershot.

[13]Bravo-Lillo, C, Cranor, LF, Downs, JS & Komanduri, S 2011, 'Bridging the gap in computer security warnings: A mental model approach', *IEEE Security & Privacy*, vol. 9, no. 2, pp. 18–26.

[14]Reason, J 1990, *Human error*, Cambridge University Press, Cambridge.

[15] NASA Federal Credit Union (NASAFCU) 2019, *Typosquatting is quickly rising: How to protect yourself*, NASA Federal Credit Union blog, https://www.nasafcu.com/blog/detail/typosquatting-quickly-rising-protect

[16]Beautement, A., Sasse, M. A., & Wonham, M. (2008). The compliance budget: Managing security behaviour in organisations. In NSPW 2008, 47–58.

[17]Dekker, S 2014, *The field guide to understanding "human error"*, 3rd edn, CRC Press, Boca Raton.

[18]Workman, M, Bommer, WH & Straub, D 2008, 'Security lapses and the omission of information security measures: A threat control model', *Computers in Human Behavior*, vol. 24, no. 6, pp. 2799–2816.

[19] Woods, E 2018, *The most common examples of a phishing email*, usecure blog, https://blog.usecure.io/the-most-common-examples-of-a-phishing-email

[20]National Cyber Security Centre (NCSC) 2019, *Secure by design: Principles for building security that works for people*, NCSC, London.

[21]Sasse, MA, Brostoff, S & Weirich, D 2001, 'Transforming the "weakest link"—a human/computer interaction approach to usable and effective security', *BT Technology Journal*, vol. 19, no. 3, pp. 122–131.

[22]Subramanian, S 2023, 'Application of the nudge theory for improving information security awareness posters', *ISACA Journal*, vol. 3, pp. 1–8.

[23]Egelman, S, Cranor, LF & Sheikh, A 2008, 'You've been warned: An empirical study of the effectiveness of web browser phishing warnings', in *CHI 2008: Proceedings of the SIGCHI Conference on Human Factors in Computing Systems*, ACM, New York, pp. 1065–1074.

6 APPENDIX
6.1 APPENDIX A: Secure System Design (Flawfinder Lab)

Term 2 Weeks 2/4 - A Usability Evaluation of Static Analysis Tools for Security
GROUP WORK: 5655691, 5643410
Part 1:
LAB PART 1: COGNITIVE WALKTHROUGH - FLAWFINDER
Screenshot 1: Scan in Progress/Completion

```
Examining ./demos/cms/cms_comp.c
Examining ./demos/cms/cms_enc.c
Examining ./demos/cms/cms_sign2.c
Examining ./demos/cms/cms_ddec.c
Examining ./demos/cms/cms_uncomp.c
Examining ./demos/cms/cms_dec.c
Examining ./demos/selfsign.c
Examining ./demos/pkcs12/pkread.c
Examining ./demos/pkcs12/pkwrite.c
Examining ./demos/prime/prime.c
Examining ./MacOS/buildinf.h
Examining ./MacOS/_MWERKS_GUSI_prefix.h
Examining ./MacOS/Randomizer.h
Examining ./MacOS/GUSI_Init.cpp
Examining ./MacOS/GetHTTPS.src/MacSocket.cpp
Examining ./MacOS/GetHTTPS.src/GetHTTPS.cpp
Examining ./MacOS/GetHTTPS.src/CPStringUtils.cpp
Examining ./MacOS/GetHTTPS.src/ErrorHandling.cpp
Examining ./MacOS/GetHTTPS.src/ErrorHandling.hpp
Examining ./MacOS/GetHTTPS.src/MacSocket.h
Examining ./MacOS/GetHTTPS.src/CPStringUtils.hpp
Examining ./MacOS/_MWERKS_prefix.h
Examining ./MacOS/Randomizer.cpp
Examining ./MacOS/opensslconf.h
```

Figure A1: Completed scan of openssl-1.0.1e test suite using flawfinder

Screenshot 2: Full Results List

Final Results

- ./crypto/rand/randfile.c:86: **[5]** (race) *chmod: This accepts filename arguments; if an attacker can move those files, a race condition results. (CWE-362). Use fchmod( ) instead.*

```
#define chmod   _chmod
```

- ./crypto/rand/randfile.c:248: **[5]** (race) *chmod: This accepts filename arguments; if an attacker can move those files, a race condition results. (CWE-362). Use fchmod( ) instead.*

```
chmod(file,0600);
```

- ./apps/ca.c:593: **[4]** (buffer) *strcpy: Does not check for buffer overflows when copying to destination [MS-banned] (CWE-120). Consider using snprintf, strcpy_s, or strlcpy (warning: strncpy easily misused).*

```
strcpy(tofree,s);
```

- ./apps/ca.c:869: **[4]** (race) *access: This usually indicates a security flaw. If an attacker can change anything along the path between the call to access() and the file's actual use (e.g., by moving files), the attacker can exploit the race condition (CWE-362/CWE-367!). Set up the correct permissions (e.g., using setuid()) and try to open the file directly.*

```
if (access(outdir,R_OK|W_OK|X_OK) != 0)
```

- ./apps/ca.c:1320: **[4]** (buffer) *strcpy: Does not check for buffer overflows when copying to destination [MS-banned] (CWE-120). Consider using snprintf, strcpy_s, or strlcpy (warning: strncpy easily misused).*

```
strcpy(buf[2],outdir);
```

- ./apps/cms.c:206: **[4]** (crypto) *EVP_des_cbc: DES only supports a 56-bit keysize, which is too small given today's computers (CWE-327). Use a different patent-free encryption algorithm with a larger keysize, such*

Figure A2: Completed scan of openssl-1.0.1e test suite using flawfinder
Total vulnerabilities found: 2949 hits

Note: This excessive volume of uncategorised data directly parallels the Alert Overload experienced by the client's staff, which leads to Tool Abandonment identified in STAR 1

KEY USABILITY ISSUES IDENTIFIED

Issue 1: User has to export results manually to HTML

Screenshot 3: Issue 1 Evidence

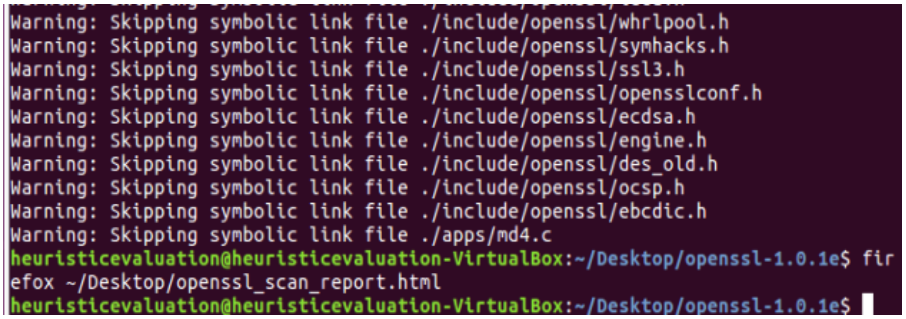


Figure A3: The terminal shows the tool process but does not give an easily comprehensible result, leading to the user having to export to a html file

What happened: After using the tool in the terminal, it displays the messages of the processing but does not display the results easily

Why it's a usability problem: The user may find it difficult to find the results of the scanning, and only after printing to a html file would it be easy to read

Issue 2: Difficult to navigate through vulnerabilities

Screenshot 4: Issue 2 Evidence

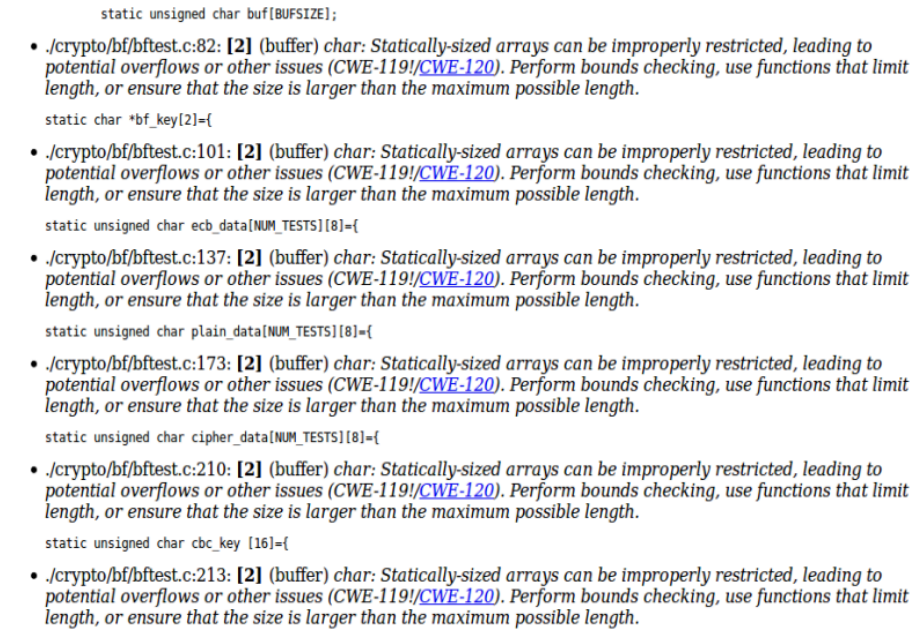


Figure A4: List of potential vulnerabilities that is hard to read

What happened: All the results are printed in the html file as a list with relevant information, without any easy way to separate each potential vulnerability found

Why it's a usability problem: Visual clutter which may impact cognitive ability and make it difficult for users to read as it is not categorised easily

Issue 3: No built-in help or tutorial
Screenshot 6

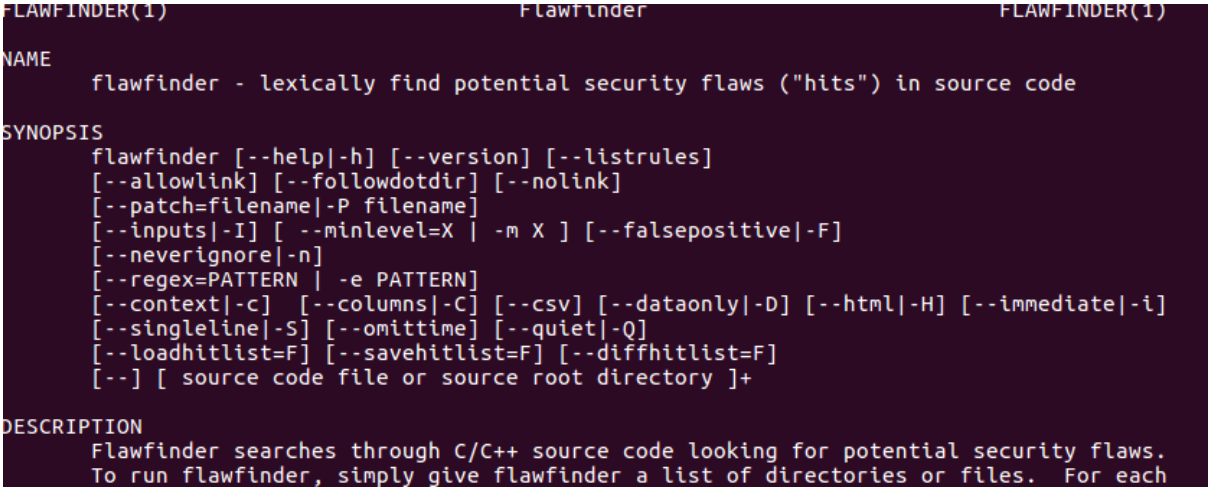


Figure A6: Limited help showing only flag listings
What happened: Flawfinder offers only a man page and –help flag listing commands with no interactive tutorial, example workflows, or beginner-friendly guidance.
Why it’s a usability problem: New users must figure out the tool independently or search external resources, increasing the barrier to entry and leading to incorrect usage.

SAMPLE VULNERABILITY

Vulnerability type: Difficulties in determining True or False positive in given context
CWE Reference: CWE-120: Buffer Overflow
Affected File: ./ssl/d1_both.c
Line numbers: 561 and 590
Risk Level: 2 (Medium)
Screenshots 7/8:
Flawfinder flagged line 561 as a medium risk [2] buffer overflow vulnerability with memcpy() but provided no context about whether the destination buffer can actually hold the source data. The warning is identical to other memcpy warnings regardless of actual risk. Developers cannot distinguish between intentional false positives and critical vulnerabilities without manually inspecting each warning's code context. This leads to wasted time on safe code while genuine security risks may be overlooked due to warning fatigue.

```
./ssl/d1_both.c:561:  [2] (buffer) memcpy:
  Does not check for buffer overflows when copying to destination (CWE-120).
  Make sure destination can always hold the source data.
./ssl/d1_both.c:590:  [2] (buffer) char:
  Statically-sized arrays can be improperly restricted, leading to potential
  overflows or other issues (CWE-119!/CWE-120). Perform bounds checking, use
  functions that limit length, or ensure that the size is larger than the
  maximum possible length.
./ssl/d1_both.c:618:  [2] (buffer) memcpy:
  Does not check for buffer overflows when copying to destination (CWE-120).
  Make sure destination can always hold the source data.
```

Figure A7

```
heuristicevaluation@heuristicevaluation-VirtualBox:~/Desktop/openssl-1.0.1e$ cat -n ./ssl/d1_
both.c | sed -n '555,565p'
   555
   556                  al=dtls1_preprocess_fragment(s,&frag->msg_header,max);
   557
   558                  if (al==0) /* no alert */
   559                          {
   560                          unsigned char *p = (unsigned char *)s->init_buf->data+DTLS1_H
M_HEADER_LENGTH;
   561                          memcpy(&p[frag->msg_header.frag_off],
   562                                  frag->fragment,frag->msg_header.frag_len);
   563                          }
   564
   565                  dtls1_hm_fragment_free(frag);
```

Figure A8

SECOND VULNERABILITY
Vulnerability type: Race Condition (Time-of-Check to Time-of-Use)
CWE Reference: CWE-362: Concurrent Execution using Shared Resource with Improper Synchronisation
Affected File: ./crypto/rand/randfile.c
Line Numbers: 86 and 248
Risk Level: 5 (Highest)

What the vulnerability does: Between the time when the program checks the file and when it changes permissions, an attacker could replace the file with a symbolic link to a critical system file or move the original file and create a malicious replacement instead, both allowing an attacker to potentially gain access to the system

Proposed fix: As Flawfinder suggests, use fchmod() instead of chmod(), as fchmod() operates on a file descriptor not pathname, and once the file is open it is locked and cannot be swapped out for another file

Screenshot 9: This Vulnerability

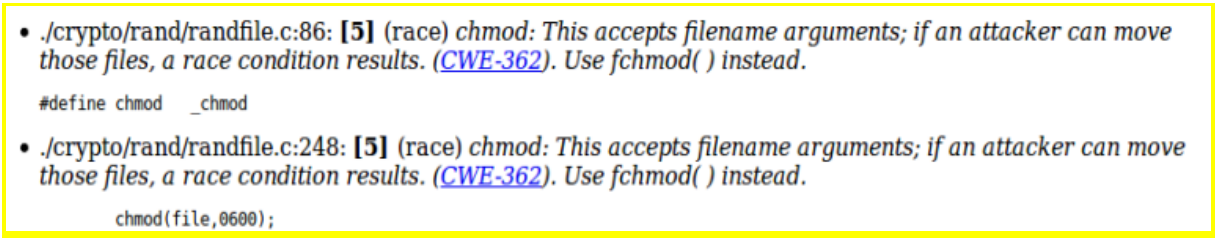


Figure A9: Examples of Race Condition with proposed fix

Note: This violates Information Needs for non-expert users, which forces them to switch from System 1 to high-effort System 2 thinking

Part 2:
LAB PART 2, PHASE 2: HEURISTIC EVALUATION - Flawfinder
EXPLORATION OVERVIEW
Screenshot 10: Exploring [Feature/Area of Tool]

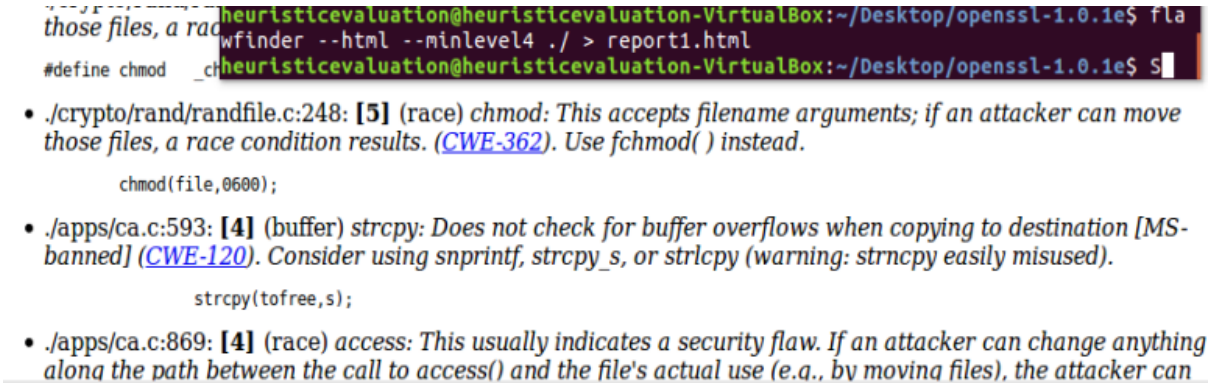


Figure A10: Improving the search results of the tool by filtering by specific risk levels - minimum level 4

MAPPING TO SMITH'S 17 INFORMATION NEEDS

Heuristic	Issue Found? (Y/N)	Description of Issue	Screenshot Reference
Preventing & Understanding Attacks	Y	Flawfinder provides CWE categorisation but no explanation of how an attacker would actually exploit each vulnerability. No attack scenarios or exploitation examples are given	Figure A2
Understanding Alt. Fixes & Approaches			
Assessing the Application of the Fix	Y	After fixing code, there is no way to verify the fix worked or compare pre or post fix results. Users must manually re-scan entire codebase	Figure A7, Figure A8
Relationship Between Vulnerabilities	Y	Multiple memcpy warnings appear independently with no indication they might be related, part of the same issue or intentional. No grouping by file, function, or vulnerability type.	Figure A4
Locating Information	Y	HTML report shows file names and line numbers but has no clickable links to code. Users must manually navigate to files in separate editors which cause context switching.	Figure A2
Control Flow and Call Information	Y	No information about callers or callees of vulnerable code is actually reachable from attacker-controlled input	-
Data Storage and Flow			
Code Background and Functionality	Y	No function documentation, code history, or context about what the code actually does. Developers must understand unfamiliar code from the basics.	Figure A8
Application Context and	Y	No distinction between test code and production code. Vulnerabilities in test files appear identical to critical production	

Usage		flaws. This wastes time on low-priority items.	
End-User Interaction	Y	No indication if vulnerability involves user input or what sanitisation or validation exists. Cannot prioritise flaws that are end users.	
Developer Planning and Self-Reflection	Y	As the report only involves html, no method to mark items as reviewed, add notes or track progress across sessions. Developers lose track of what's been fixed.	Figure A1, Figure A2
Understanding Concepts	Y	CWE numbers are provided but with no explanation of what they mean. Junior developers cannot learn about vulnerability types within the tool.	Figure A4
Confirming Expectations			
Resources and Documentation	Y	Displays the CVE and other context of the potential vulnerability	Figure A9
Understanding and Interacting with Tools	Y	CLI only with flags must be memorised. Causes mental strain towards users	Figure A6
Vulnerability Severity and Ranking	Y	Displays the risk level of each potential vulnerability on a scale of 1 (lowest) to 5 (highest) risk	Figure A9
Notification Text	Y	generic , repetitive messages appear for every flaw warning regardless of context.	Figure A4

Note: There is a critical breakdown in the feedback loop, where the lack of Visibility of System Status removes the user's sense of progress, decreasing their motivation to report future threats

ADDITIONAL ISSUES (Not covered by heuristics)
Issue A: HTML report has no navigation or bookmarking
Screenshot 11:

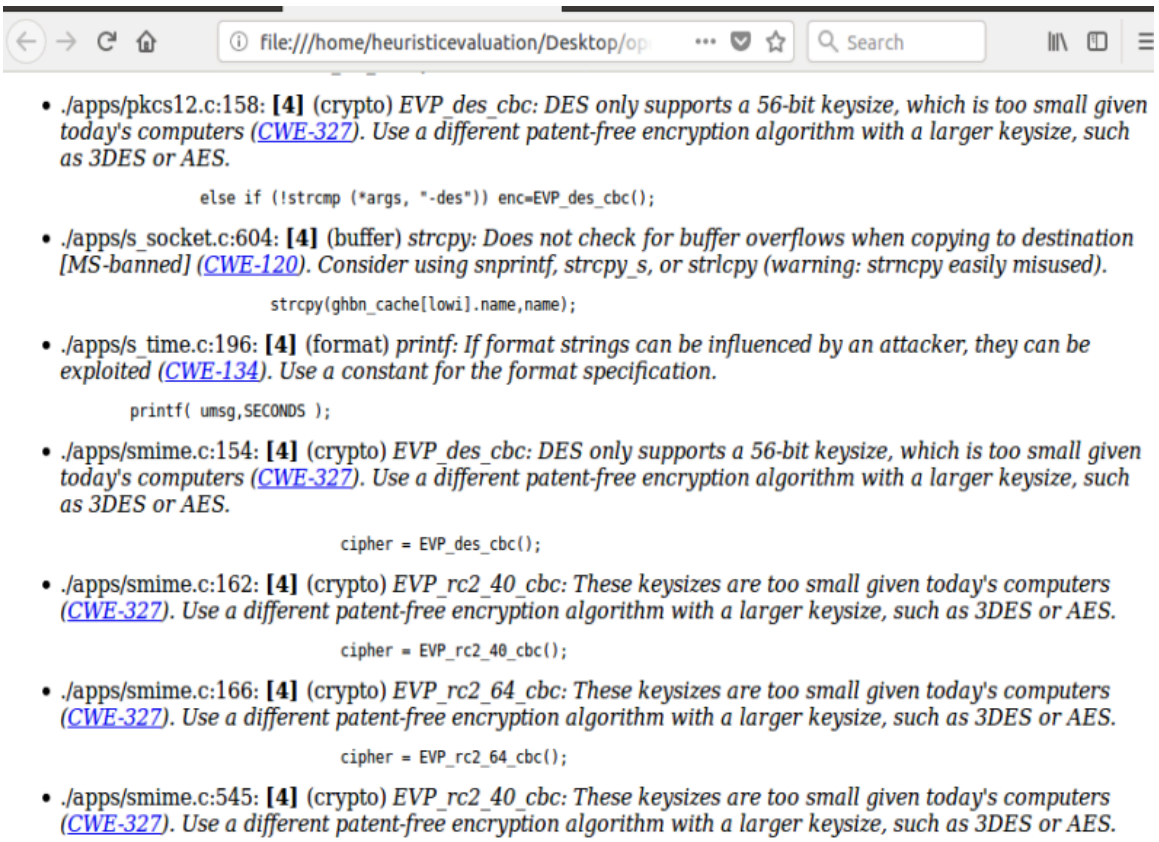
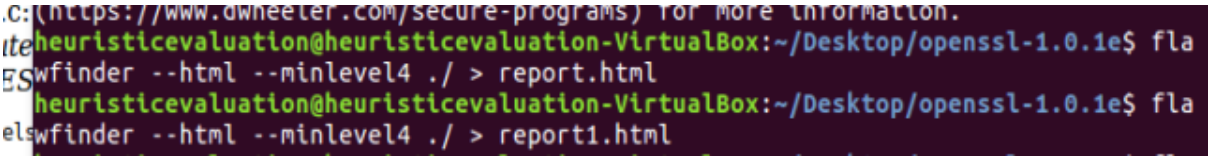


Figure A11: HTML output is a single long page with no table of contents

Issue B: No way to save scan configuration or exclude directories
Screenshot 12:



igure A12: User must manually type scan parameters each time

THEMATIC ANALYSIS

Theme 1: Information Poverty

- Issues under this theme:
- Incomplete fix examples (Heuristic: Understanding Alternative Fixes)
- No call flow context (Heuristic: Control Flow and Call Information)
- Example screenshot: Figure A11

Theme 2: Poor Prioritisation Support

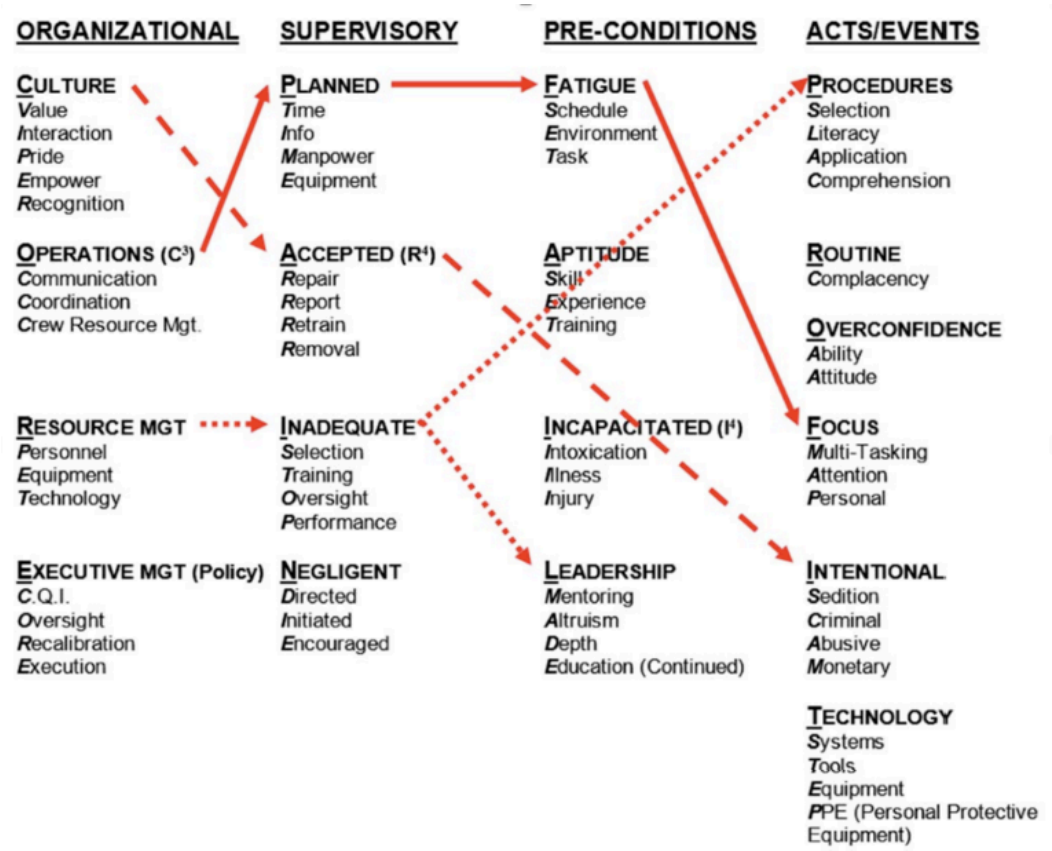
- Issue under this theme:
- Risk levels provided but not explained (Heuristic: Vulnerability Severity and Ranking)
- No filtering or sorting in HTML output (Heuristic: Locating Information)
- Cannot group related vulnerabilities (Additional Issue A)
- High false positive rate wastes time (Heuristic: Confirming Expectations)
- Example screenshot: Figure A11

Theme 3: Steep Learning Curve

- Issue under this theme:
- Command-line only with no GUI (Heuristic: Understanding and Interacting with Tools)
- Technical terms unexplained (Heuristic: Understanding Concepts)
- No interactive features (Additional Issue B)
- Example screenshot: Figure A12

6.2 APPENDIX B: Human Error (HEAT Framework Lab)

Term 1 Week 9 - HEAT Lab
LAB: HEAT FRAMEWORK ANALYSIS
Group members: 5655691, 5643410
PART 1: UNDERSTANDING THE HEAT FRAMEWORK
Screenshot 1: HEAT Framework Diagram



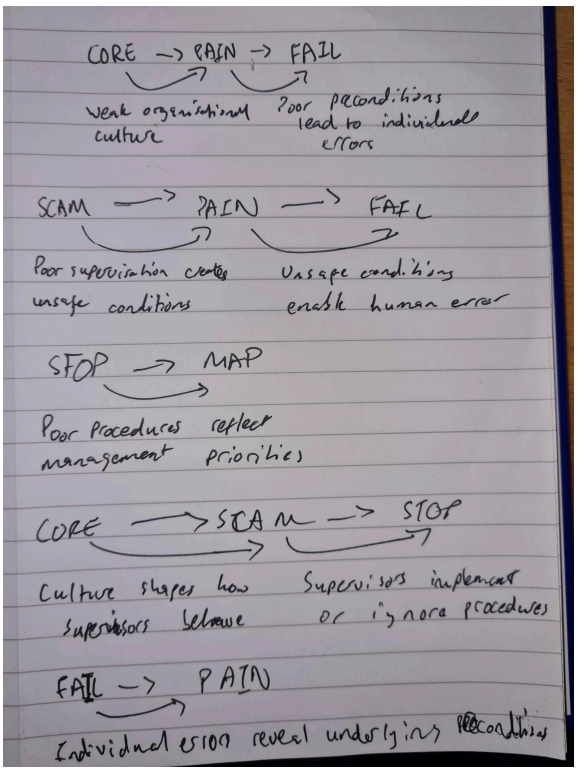
Caption: Figure B1: The HEAT framework showing the four areas of influence and relationships [Garrett & Teizer, 2009]

The four areas of influence:

Area	What it means
Organisational Culture	The shared system of values, beliefs and behaviour that define how members of an organisation interact, work and make decisions
Supervisory Influences	How a leader is able to affect subordinate behaviour, performance and development through expert knowledge and trust rather than just authority
Preconditions	The set of background environmental, atmospheric or social factors existing before an extreme event
Standard operating procedures	Detailed, written document that outlines step by step instructions for routine, complex tasks in order to ensure consistency, safety and efficiency across an organisation. Effective SOPs reduce errors, guarantee compliance and serve as a guide for employees

Table B1: Four areas of influence in our own words

PART 2: MAPPING HEAT ACRONYMS
Screenshot 2: My Brainstorming Notes



Caption: figure B2: Initial brainstorming of relationships between HEAT acronyms

Relationships I identified:

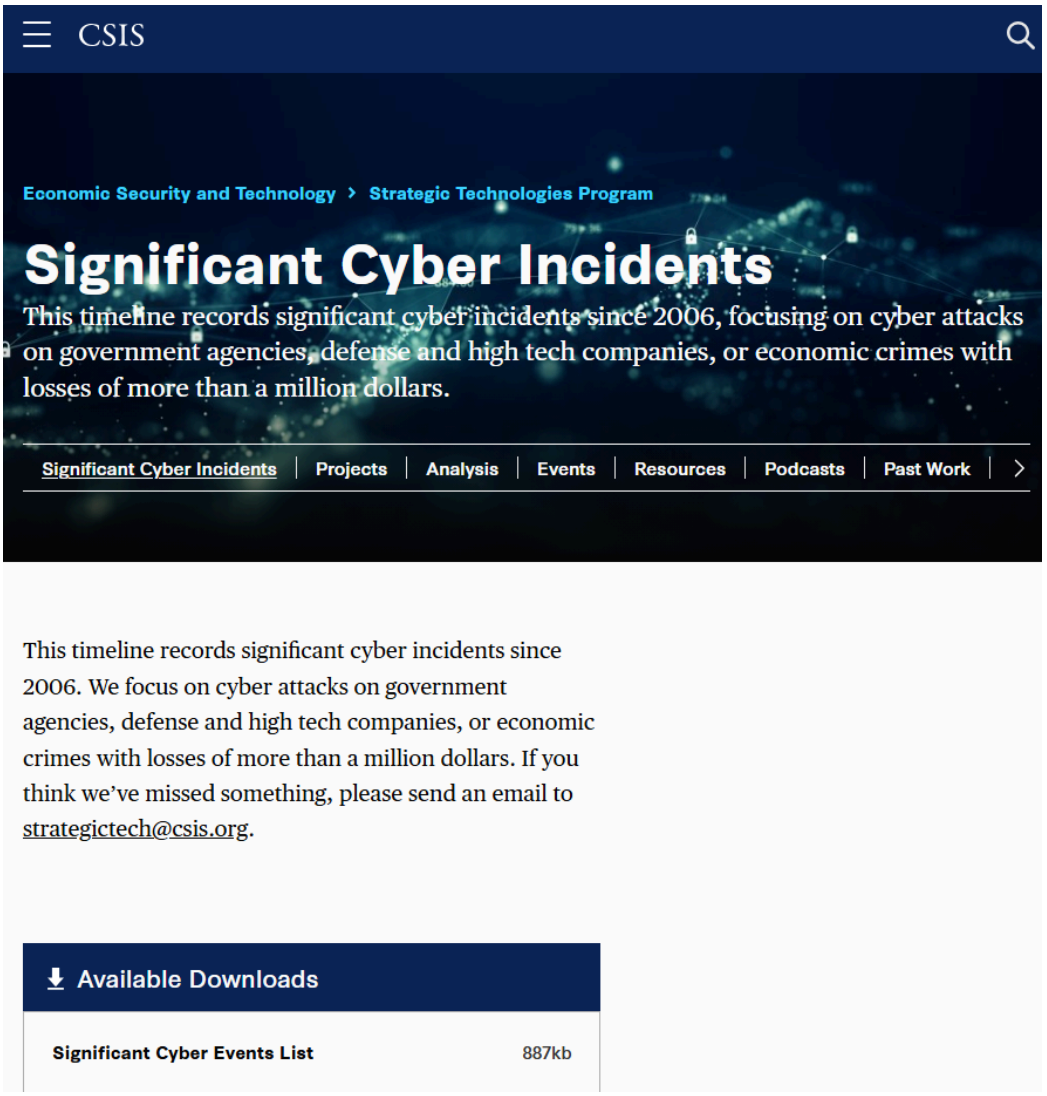
Relationship	Explanation
CORE → PAIN	A weak organisational culture (CORE) creates conditions where employees are more likely to make errors (PAIN)
PAIN → FAIL	Negligent oversight (PAIN) creates negative preconditions such as employee fatigue due to poor scheduling or lack of aptitude due to missed training (FAIL)
FAIL → ACTS	When preconditions like fatigue or lack of focus exist (FAIL), they manifest as specific errors such as procedural lapses, overconfidence, or the misuse of technology (ACTS)
CORE → FAIL	The organisational Culture (CORE) determines whether employees value and strictly follow standard operating Procedures (ACTS) or view them as obstacles to be bypassed
EXEC → NEGL	Poor Executive Management policy (CORE) shift into Negligent supervisory practices (PAIN) as there is no high-level oversight or recalibration of security goals

Table B2: HEAT links identified

Note: This displays statistical proof that under time pressure, users tend to skip the Verification step of their mental model, which leads to successful phishing

PART 3: CONNECTING TO REAL-WORLD BREACHES

Screenshot 3: Research Notes



Caption: Figure B3: Researching real-world data breaches to analyse through the HEAT lens

Breaches from Lab Document:

Breach	What happened	HEAT Link	HEAT Area
Equifax (2017)	Failure to patch known vulnerability in Apache Struts	STOP (failure to follow procedures)	Standard Operating Procedures
Target (2013)	Vendor phishing email led to network access	SCAM (vendor not properly trained)	Preconditions
Capital One (2019)	Misconfigured firewall	MAP (misconfiguration due to oversight failure)	Supervisory influences?
Colonial Pipeline (2021)	Compromised passwords with lack of MFA	FAIL (password reuse/weak authentication)	Organisational Culture?

Table B3: Breaches identified from the lab sheet

Additional Breaches Our Group Researched:
Breach 1: North American Casino Fish Tank Breach
Brief description: In 2017, hackers gained access to a casino's interval network by exploiting a vulnerability in a "smart" thermometer used to monitor a large lobby fish tank. They eventually exfiltrated 10GB of data to a server in Finland after breaching the IoT device and moving laterally via network to the casino's database.

Screenshot 4: 

Forbes

Caption: Figure B4: Source material for North American Casino Fish Tank Breach analysis.

HEAT analysis (group consensus):

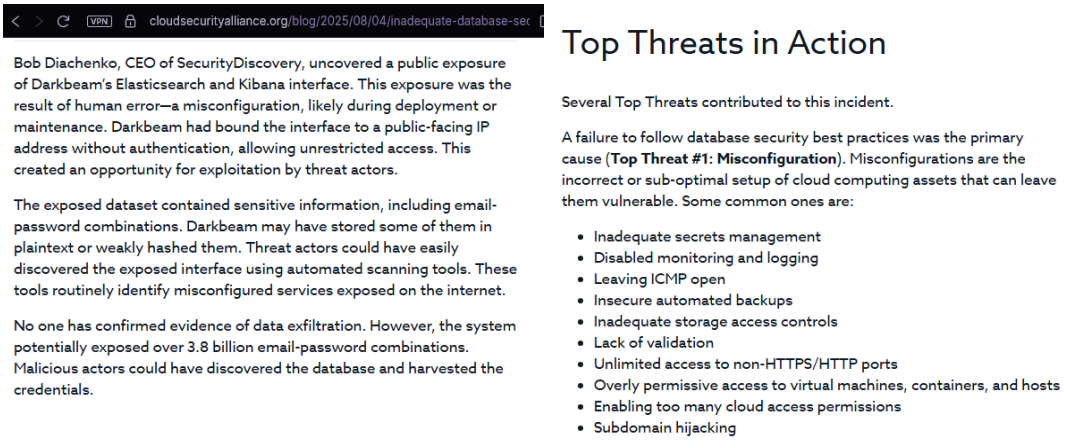
HEAT Area	Involved? (Y/N)	How?
Organisational Culture	Y	The organisation prioritised "interaction" and "Pride" (the aesthetic of the techy tank) over security "Value" leading to a culture where IoT convenience outweighed risk management
Supervisory Influences	Y	There was a failure in the PLANNED stage where management failed to provide "Oversight" regarding how a third party IoT device was integrated into the organisation network
Preconditions	Y	Technology, Aptitude The thermometer was a weak link in terms of hardware and there may have been a lack of "Training" or "Experience" in securing IoT devices among staff
Standard Operating Procedures	Y	Procedures specifically Application. Standard security protocols should have required network segmentation but these were not applied

Table B4: Heat analysis for North American Casino Fish Tank Brief

Note: Operational speed was prioritised over security verification protocols, aligning with the client's "CORE" failure

Breach 2: DarkBeam (2023)
Brief description: 3.8 billion records exposed, DarkBeam was a company whose business was “protecting you from data breaches”. These credentials were exposed because they misconfigured their own infrastructure

Screenshot 5: Breach 2 Source



Caption: Figure B5: Source material for DarkBeam analysis [cloudsecurityalliance.org]

HEAT analysis (group consensus):

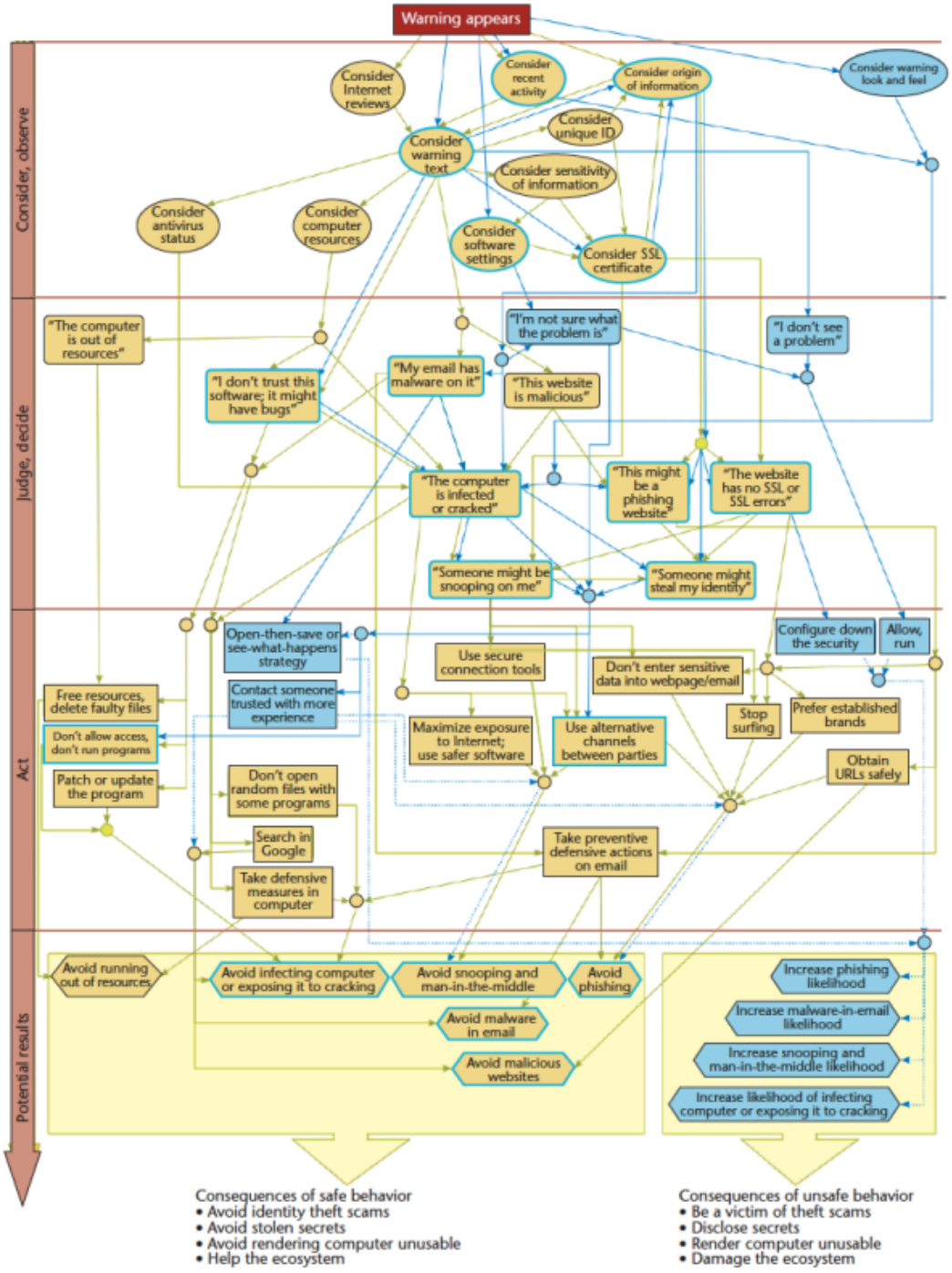
HEAT Area	Involved? (Y/N)	How?
Organisational Culture	Yes	Security was treated as an afterthought as opposed to a core value. As a data protection firm, their business is selling security to others, yet failed to apply basic security to their own systems. Suggests a culture where they tell customers to do as they say, not as they do.
Supervisory Influences	Yes	Leadership failed to provide oversight, as management did not supervise or audit the work of the IT team that was trusted with critical security tasks. No process to ensure that after maintenance or deployment, configurations were actually secure. Also failed to enforce mandatory security training
Preconditions	Yes	Untrained or poorly trained employees. Elasticsearch/Kibana interface was bound to a public IP address with no password or authentication. Basic, fundamental error that suggests the staff member responsible did not know how to secure it properly or didn't understand why it mattered. Likely “forgot to set password after maintenance” - a precondition of fatigue or lack of awareness
Standard Operating Procedures	Yes	No secure configuration procedures existed or were ignored. No mandatory security checklist before deployment, no requirement to enable authentication by default. No regular audits of cloud configurations or requirements for MFA on internal systems. If they did exist, they were not followed

Table B5: HEAT analysis for DarkBeam breach
Note: These “FAIL” preconditions parallelthe client’s remote work environment, which proves that environmental pressure results in clicking links, not user stupidity

6.3 APPENDIX C: Warning Response (Mental Models Lab)

Term 1 Week 3 - Mental models lab
LAB: MENTAL MODELS
Group members: 5655691, 5643410

PART 1: UNDERSTANDING THE MODEL
Screenshot 1: Mental Model of Warning Response Behaviour



Caption: Figure C1: Mental model of warning response behaviour showing how novice and advanced users process computer alerts [Bravo-Lillo et al., 2010]

In my own words, what does this model show?
The model shows different thought processes and behaviours that novice and advanced users go through when they encounter a computer security warning. There are 3 main stages a user moves through after a warning dialogue pops up. The first is Observation/Consideration (what they notice), Diagnosis/Judgement (what they think is happening) and Action/Response (what they do about it). The main insight is that novice and advanced users think differently throughout each stage, novices rely on superficial cues such as how it looks, while advanced users consider context, search for information and make reasoned judgements. These different mental models explain why some users ignore critical warnings whilst some others respond appropriately.

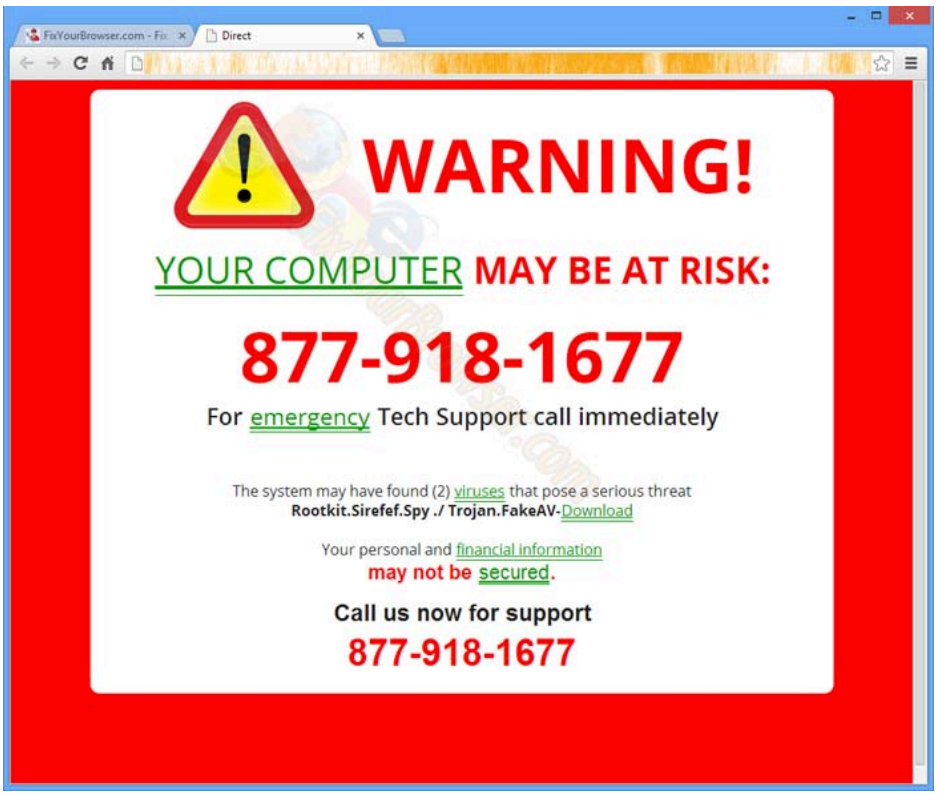
Key differences between novice and advanced users:

Stage	Novice Users (Blue)	Advanced Users (Yellow)
Observation/Consideration	Focus on surface-level features, based on how the warning looks and feels, such as a familiar logo, colours or fonts. They notice whether it looks “scary” or “official”, and they rarely read the actual text carefully	Consider the context and any technical details. Their recent actions, the warning text, the source, and whether the warning is consistent with their current activity
Diagnosis/Judgement	Make emotional or simplistic judgements. Often dismissive and rely on intuition rather than evidence	Make reasoned, evidence-based judgements: compare the warning to known patterns, search the text online, check if the warning is legitimate and consider whether their current behaviour is actually risky
Action/Response	Take binary actions: either click “Cancel/Close” to make it go away, click “OK/Allow” to proceed with what they were doing or ignore it completely. Often chooses path of least resistance	Take nuanced, investigative actions by searching for more information, consulting documentation or colleagues, making informed decisions based on research or take measured risks after weighing consequences

Note: Validates why client staff are deceived by “Visual Authenticity” (such as a Microsoft logo) despite technical inconsistencies in the sender address
Note: Explains the 'Information-Action Gap': users perceive a crisis and click quickly rather than investigating

PART 2: CHOOSING A WARNING TO ANALYSE

Screenshot 2: My Chosen Warning



Caption: Figure C2: Browser redirect to scam website

Warning type: Big red sign
Where it appears: In the browser
What triggers it: Clicking a link that redirects the user

PART 3: ANALYSING THE WARNING THROUGH THE MENTAL MODEL

Stage 1: Observation/Consideration

User Group	How might they observe/consider this warning?	Issues?
Novice	Primarily focuses on the image and feel the atmosphere from the bright red background and large “WARNING” text with urgency	Overwhelmed by design cues leading to a high emotional response and reduced critical thinking
Advanced	Considers the origin of information from the URL and the specific warning text	May be momentarily distracted by the specific technical terminology, though they are more likely to notice the lack of a secure SSL certificate for a supposed “support” site

Stage 2: Diagnosis/Judgement

User Group	What might they diagnose/judge is happening?	Issues?
Novice	They might think that they actually have malicious files on their device after reading all the warnings and underlined information that they may worry about as it refers to their sensitive information	By having a lack of awareness and training for these types of attacks, the user may be tricked into believing that they actually have malicious files on their device, and this may lead to them making uninformed decisions about the situation
Advanced	They may notice that it is a browser redirect and that it is unlikely that the browser has been able to suddenly detect that their device contains malicious information, in which case they are unlikely to believe it and suspect that it is part of a scam as opposed to being legitimate	Whilst advanced users won’t fall for the scam, the warning interrupts their workflow and creates annoyance, as they must close the tab or force-quit the bowser

Stage 3: Action/Response

User Group	What action might they take?	Issues?
Novice	They might click on the green links or call the phone number	The phone number or links may be leading to scam websites/numbers, in which case the user, already in their nervous state, may think irrationally and do whatever they are asked to do, for example payment or logging into an account, which may compromise them further
Advanced	Search online the phone number or error message, in order to verify the legitimacy of the website or how to move past this issue	Time wasted, frustration that browsers allow these traps. Limited reporting tools means that reporting scams is often long and feels like it does nothing. No way to warn others as they can close it but other people might still be stuck

PART 4: PROPOSED IMPROVEMENTS
Based on the mental model, how could this warning be redesigned to better support BOTH user groups?

ASSUMES THAT THIS IS A LEGITIMATE WARNING

Improvements 1: Clearer visual cues
The warning would be improved by changing the sizes of the fonts, so that the phone number is not the biggest, and it should be laid out better for readability and so that users are able to identify quickly what the issue is, and the steps they need to take
Which stage of the model does this address? Stage 1
Which user group does it help most? Novice users

Improvement 2: Replace fear with facts
Provide the user with information about the attack, such as where the malicious files are located, any information that may help the user such as links to browser to explain more about the error, instead of scaring the user by saying things like “you will lose all data” etc, and provide ONLY meaningful information

Which stage of the model does this address? Stage 1 and indirectly Stage 2
Which user group does it help most? Novice users

Improvement 3:Integrated Safe Action Pathways
Remove all external contact information (phone numbers/links) and replace them with a single, prominent “Close and Run Trusted System Scan” button
Which stage of the model does this address?
Stage 3 (Act/Response)
Which user group does it help the most?
Both however it primarily supports Novice users. By providing a safe alternative to “contacting someone” or “using what happens” strategies, it prevents the novice from taking the unsafe path of calling the scammer. It also gives the expert a direct route to “ patch or update” or “take defensive measures” within a trusted environment.

Note: This lab-validated redesign is the blueprint for the STAR 3 “One-Click” reporting button, moving security from a burden to a much more seamless workflow

6.4 APPENDIX D: Behavioural Change (CyberSafe Lab)

Term 2 Week 1 Lab Offering Feedback on CyberSafe
LAB: OFFERING FEEDBACK ON CYBER SAFE

PART 1: RESEARCH OTHER TRAININGS
Task: Identify other relevant cyber security awareness trainings and note their unique features

Screenshot 1: Research in Progress

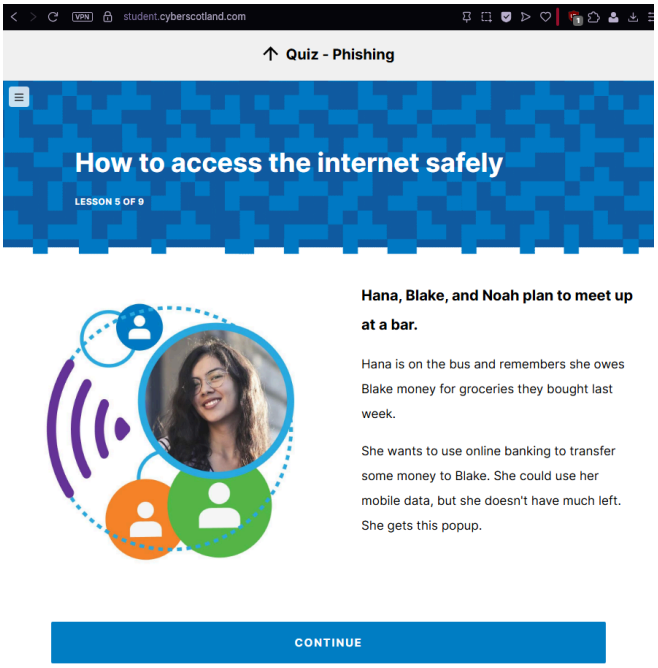


Caption: Figure D1: Researching existing cyber security training programmes for comparison

Trainings I identified:

Training Name	Provider	Unique Features/Topics	Target Audience	URL/Source
1. NCSC Certified Training scheme	NCSC	List of certified courses, various topics	Varies	ncsc.gov.uk/information/certified-training
2. Cyber Resilience and You	CyberScotland	Created by students for students by using multiple-choice game format with scenarios, developed with the Scottish Government and NCSC	University students	https://student.cyberscotland.com/?utm_source=universities&utm_medium=emails&utm_campaign=cyber_training_tool#/
3. KnowBe4 Student Edition	KnowBe4	Trained 1 million+ students, uses humorous content and peer-to-peer learning	Students and educational institutions	https://www.knowbe4.com/products/knowbe4-student-edition

Screenshot 2: Training Example 1

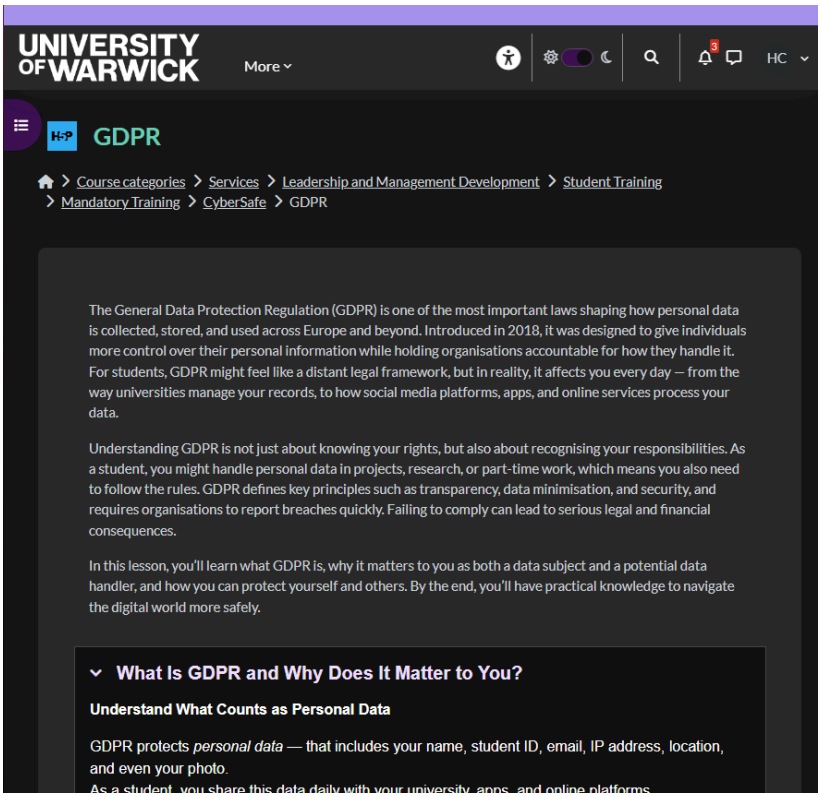


Caption: Figure D2: Cyber Resilience and You - Provides information, scenarios and quizzes to teach and test users knowledge

PART 2: STRUCTURED COMPARISON

Feature	Cyber Safe	Other Trainings (summarise)
Target audience	University students	Varies (NCSC), Students (CyberScotland), students and institutions (KnowBe4)
Topics covered	General cyber security awareness	Varied: Student-like scenarios and advanced topics
Delivery method	Online training (moodle)	Varied: Interactive game, video-based, simulations
Length/format	Short	Flexible: Short scenarios or continuous adaptive micro-learning
Interactivity	Basic module interaction, quizzes etc	Gamified challenges, leaderboards, simulations
Assessment	Acknowledgement of task completed	Continuous: Simulation results, knowledge checks
Certification	Moodle confirmed to be complete	NCSC Certified Training offers a recognised external quality benchmark, others offer certificates
Mandatory status	Yes (from Sep 2025)	Often mandatory

Screenshot 3: Cyber Safe Content Evidence



Caption: Figure D3: Example of Cyber Safe training content

PART 3: CYBER SAFE STRENGTHS

Strength	Justification (why is this good?)
1. High uptake	1985 students completed within 2 weeks - shows engagement
2. Strategic Alignment	Addresses a top institutional risk and mandatory for all newcomers, ensuring a baseline level of awareness
3. Collaborative Development	Developed by the Cyber Security Centre in collaboration with the Information Security Team and students

PART 4: CYBER SAFE AREAS FOR IMPROVEMENT

Area for improvement	Justification (why is this a problem?)	Suggested Fix
1. Engagement & Relevance for Students	Research shows peer-to-peer learning and gamified, scenario-based content is more effective than passive online modules	Introduce gamified elements and student-life scenarios such as the interactive modules like spotting phishing emails
2.Lack of Continuous/Adaptive Learning	A one-time course for newcomers creates a static knowledge base. Cyber threats evolve and a single session does not reinforce learning or adapt to new risks	Implement a continuous learning model. Could include short training refreshers, simulation exercises and targeted campaigns around emerging threats
3. Assessment of Effectiveness	The success metric is “completion rates”, measuring activity not showing if students actually change their behaviour	Move beyond completion metrics by tracking behaviour change such as measuring rate of students reporting real or simulated phishing emails over time Move beyond completion metrics by tracking behaviour change and implement immediate, constructive feedback looks
4. Lack of Role-Based Customisation	Different students have different access to sensitive data, the current approach may miss specific risks for certain groups	Develop differentiated content, such as creating additional modules for specific groups to make training more relevant and personal

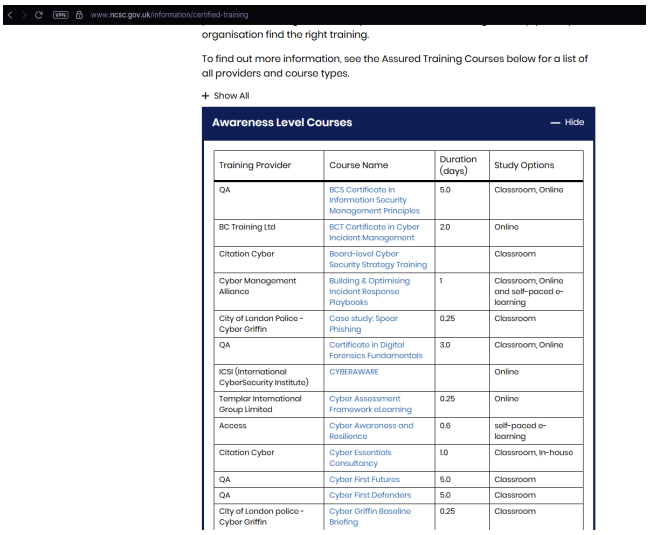
Note: Proves that the client’s current compliance-based training is ineffective at bridging the Information-Action Gap

Note: The Actionable Feedback loop was integrated into the STAR 3 redesign to satisfy the Motivation variable of the Kainda Model, turning a dry compliance task into a rewarding user action

PART 5: NCSC REFERENCE EVIDENCE

https://www.ncsc.gov.uk/information/certified-training

Screenshot 4: NCSC Certified Training Page



www.ncsc.gov.uk/information/certified-training

organisation find the right training.

To find out more information, see the Assured Training Courses below for a list of all providers and course types.

+ Show All

Awareness Level Courses — Hide

Training Provider	Course Name	Duration (days)	Study Options
QA	BCS Certificate in Information Security Management Principles	5.0	Classroom, Online
BC Training Ltd	BCT Certificate in Cyber Incident Management	2.0	Online
Citation Cyber	Board-level Cyber Security Strategy Training		Classroom
Cyber Management Alliance	Building & Optimising Incident Response Playbooks	1	Classroom, Online and self-paced e-learning
City of London Police - Cyber Griffin	Case study: Spear Phishing	0.25	Classroom
QA	Certificate in Digital Forensics Fundamentals	3.0	Classroom, Online
ICSI (International CyberSecurity Institute)	CYBERAWARE		Online
Templar International Group Limited	Cyber Assessment Framework eLearning	0.25	Online
Access	Cyber Awareness and Resilience	0.6	self-paced e-learning
Citation Cyber	Cyber Essentials Consultancy	1.0	Classroom, In-house
QA	Cyber First Futures	5.0	Classroom
QA	Cyber First Defenders	5.0	Classroom
City of London police - Cyber Griffin	Cyber Griffin Baseline Briefing	0.25	Classroom

Caption: Figure D4: NCSC certified training directory - used as benchmark for comparison

What I learnt from NCSC guidance:
The NCSC Certified Training scheme provides a benchmark for others, emphasising the assessment of high-quality training against an exacting standard and its content should be mapped to a recognised body of knowledge. This shows how important it is to not just have training but also ensure it is of high quality and easy to understand. It distinguishes between awareness for newcomers and in-depth application for professionals, which suggests that the university may need varied levels of training for different groups.

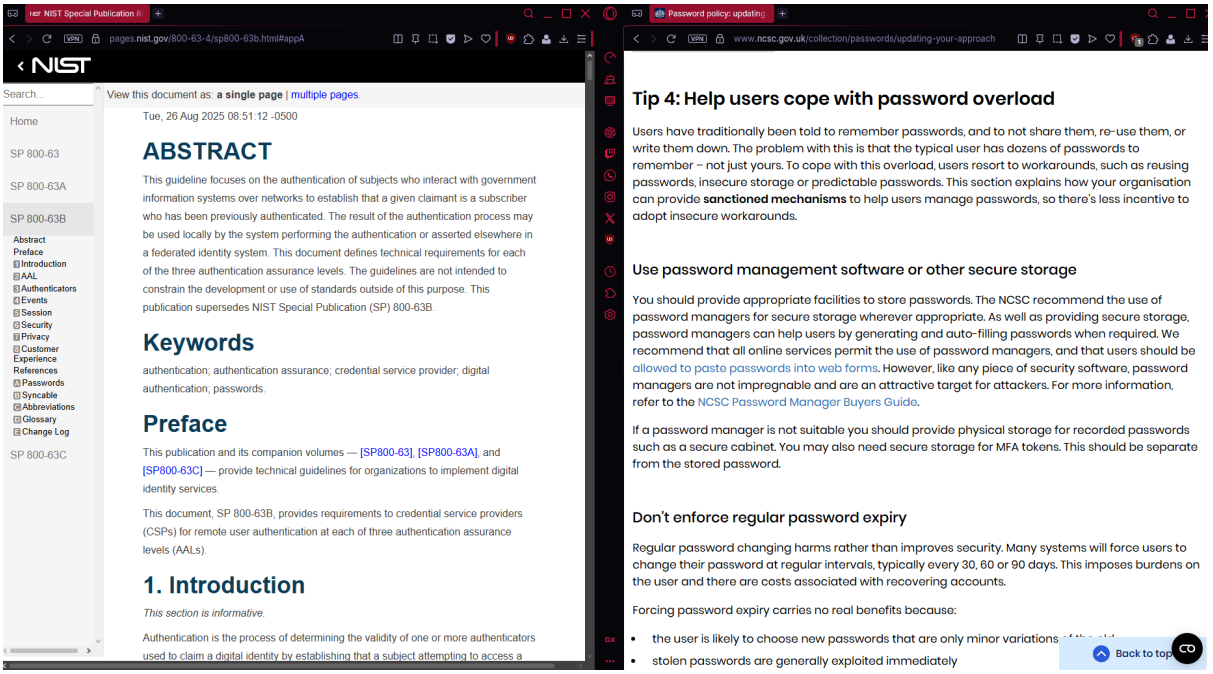
6.5 APPENDIX E: Authentication (Password Lab)

Term 2 week 5: password exercise
LAB: PASSWORD EXERCISE
Solo Work

PART 1: UNDERSTANDING MODERN BEST PRACTICE
Modern password guidance:

Source	Key Recommendations
NIST SP 800-63B	- Minimum 8 chars, longer encouraged - No mandatory complexity rules - No arbitrary password changes - Check against breached password list - Allow pasting for password managers
NCSC Guidance	- User password managers - Length > complexity - Don't force regular changes - Block common passwords
Usable Security Principles	- Reduce memory burden - Avoid frustrating rules that lead to workarounds - Support instead of punish users

Screenshot 1: Research Evidence



Caption: Figure E1: Modern password best practice guidance from NIST and NCSC

PART 2: EVALUATION OF POLICY A
Screenshot 2: Policy A

Policy A

- Minimum length: 8 characters
- Must include upper case, lower case, number, and symbol
- Must change password every 30 days
- Cannot reuse last 3 passwords
- Maximum length: 16 characters
- Account locks after 3 failed login attempts

Caption: Figure E2: Policy A for evaluation

Analysis:

Criteria	Rating (1-5)	Justification
Security	2	8 char min is weak, 30 day changes creates predictable patterns
Usability	2	Frequent changes + complexity
Real-world practicality	2	30 day changes increases helpdesk load
Compliance likelihood	2	Fails NIST standards

Strengths:
1. Account lockout
2. Prevents password reuse
3. 8 characters minimum creates a minimum

Weaknesses:
1. 16 char maximum prevents passphrases and password managers
2. 30 day forced changes reduces security
3. Complexity rules required - NIST says “shall no” impose arbitrary composition rules
4. No screening against breached passwords

Usability implications:
Users will:
- Write passwords on sticky notes as its too hard to remember
- Use predictable patterns
- Get locked out more frequently, leading to more IT support calls

How this policy might encourage insecure behaviour:
The 30 day change rule and added complexity creates weaker security because users make minimal and predictable changes

PART 3: EVALUATION OF POLICY B
Screenshot 3: Policy B

Policy B

- Minimum length: 12 characters
- No complexity rules
- Password never expires unless there is a security incident
- Password manager use is recommended
- Pasting into login fields is allowed
- Account locks after 10 failed attempts, unlocks after 15 minutes

Caption: Figure E3: Policy B for evaluation

Analysis:

Criteria	Rating (1-5)	Justification
Security	4	Strong foundation, missing only breached password screening
Usability	5	Excellent - no arbitrary rules and supports password managers
Real-world practicality	5	Very practical - reduces helpdesk calls and user-friendly
Compliance likelihood	4	Aligns with NIST except blocklist requirement

Strengths:
1. No complexity rules - follows NIST guidance
2. No forced expiry
3. 12 char minimum
4. Supports password managers
5. Reasonable lockout

Weaknesses:
1. Missing breached password screening
2. 15+ chars recommended for high-risk

Usability implications:
Users can create memorable passphrases, use password managers, and do not need to change every 30 days

How this policy might encourage secure behaviour:
Users will follow this policy because it’s not punishing. They can use password managers, and create strong but memorable passwords

PART 4: EVALUATION OF POLICY C
Screenshot 4: Policy C

Policy C

- Length must be between 14–20 characters
- Must include uppercase, lowercase, number, symbol *and* emoji
- Forced password change every 60 days
- No use of dictionary words
- Password manager use prohibited
- No repeated characters allowed
- Locked out for 1 hour after 5 failed attempts

Caption: Figure E4: Policy C for evaluation

Analysis:

Criteria	Rating (1-5)	Justification
Security	1	Seems “strong” but encourages predictable patterns and bans password managers
Usability	0	Impossible to remember
Real-world practicality	0	Cause massive helpdesk calls and workarounds
Compliance likelihood	0	Violates nearly all NIST principles

Strengths:
1. 14 char minimum is good
2. Lockout exists

Weaknesses:
1. Overly complex (why emoji?)
2. Forced 60 day changes is counterproductive
3. No dictionary words - arbitrary, unenforceable
4. Bans password managers
5. No repeated characters - arbitrary rule

Usability implications:
Users will:

- Write passwords on sticky notes
- Reuse same password with slight variations
- Constantly get locked out

How this policy might encourage insecure behaviour:
Banning password managers and requiring impossible complexity forces users into insecure workarounds
Note: Evidence of Complexity Theater which leads to Cognitive Depletion, which leaves users with less mental energy to detect phishing

PART 5: RECOMMENDED IMPROVEMENTS

For Policy A:

Recommendation	Justification	Expected Benefit
Remove complexity rules	NIST says “shall not” impose them	Users choose longer, memorable passwords
Remove 30 day expiry	Forced changes reduce security	No more patterns
Increase max length	Enables passphrases or password managers	Better security, better UX
Add breached password screening	NIST requirement	Blocks known compromised passwords
Increase lockout to 5 attempts	3 is too low for legitimate users	Reduces frustration but maintains security

For Policy B:

Recommendation	Justification	Expected Benefit
Add breached password screening	NIST requirement, only missing element	Blocks known compromised passwords
Consider 15+ chars for privileged accounts	Extra protection for administrators	Enhanced security where needed

For Policy C:

Recommendation	Justification	Expected Benefit
Remove ALL complexity rules	NIST requirement	Users can create memorable passphrases
Remove 60-day expiry	Counterproductive	No more patterns
Allow password managers	Critical for security	Enable unique strong passwords
Remove “no dictionary words”	Unenforceable and arbitrary	Reduces user frustration
Add breached password screening	NIST requirement	Real security instead of fake rules
Reduce lockout to 10 attempts, 15-min unlock	Excessive	Better UX, same security

PART 6: MY MODEL POLICY

My Model Password Policy
Based on modern best practice (NIST, NCSC) and balancing security, usability and human behaviour:
1. Minimum password length: 12 chars or 15+ for admins
2. Max password length: At least 64 chars to accommodate passphrases and password managers
3. No mandatory complexity rules
4. No forced password changes except when a compromise is suspected or confirmed
5. Passwords screened against breached password databases
6. MFA required on all accounts
7. Password manager use is encouraged and supported
8. Rate limiting on login attempts to prevent automated attacks

Explanation of key design choices:
The policy balances real security such as length, breach screening and MFA, with usability such as no annoying changes and allowing password managers, following evidence-based NIST guidance rather than outdated “complexity theater”

Note: Strategic shift to NIST-aligned standards, designed to reduce Memory Burden and align with human recall capabilities

6.6 AI Declaration:

I used AI to check over the report and give suggestions, critically evaluating responses.
Examples include asking chatgpt for synonyms of words or how to phrase sentences so that it flows better
SPAG checking
Structure advise: how to layout/headings